

Seven Seas A-6

Security Audit

May 14, 2024

Version 1.0.0

Table of Contents

- [Introduction](#)
- [Overall Assessment](#)
- [Specification](#)
- [Source Code](#)
- [Issue Descriptions and Recommendations](#)
- [Security Levels Reference](#)
- [Issue Details](#)
- [Disclaimer](#)

Introduction

This document includes the results of the security audit for Seven Seas's smart contract code as found in the section titled 'Source Code'. The security audit was performed by the Macro security team on May 12th 2024.

The purpose of this audit is to review the source code of certain Seven Seas Solidity contracts, and provide feedback on the design, architecture, and quality of the source code with an emphasis on validating the correctness and security of the software in its entirety.

Disclaimer: While Macro's review is comprehensive and has surfaced some changes that should be made to the source code, this audit should not solely be relied upon for security, as no single audit is guaranteed to catch all possible bugs.

Overall Assessment

The following is an aggregation of issues found by the Macro Audit team:

Severity	Count	Acknowledged	Won't Do	Addressed
Medium	1	-	-	1

Seven Seas was quick to respond to these issues.

Specification

Our understanding of the specification was based on the following sources:

Source Code

The following source code was reviewed during the audit:

- **Repository:** [boring-vault](#)
- **Commit Hash:** 449d919e4cf15303aa0fee848f0bd1627836b18f

Specifically, we audited the following contracts within this repository.

Source Code	SHA256
src/base/DecodersAndSanitizers/Protocols/ SwellSimpleStakingDecoderAndSanitizer.sol	b9b67816dcb7efa3b34c9a2b12a60fadb0 284478c83cd36b290cb42093204c09
src/base/DecodersAndSanitizers/Protocols/ ZircuitSimpleStakingDecoderAndSanitizer.sol	5b27e8dde63cd334ec1db5cdddb07ce543 5f7cbf11b4867c16e4728ac63ea819
src/helper/GenericRateProvider.sol	779c57758c7b1fac8460abeaefb6fd637c d134ee1bd2fe9d5e00488da25ba92e
src/base/DecodersAndSanitizers/Protocols/ EigenLayerLSTStakingDecoderAndSanitizer .sol	477589f503105a92ffc99b923baf6d135e cda145b469a300cace56017906807e

Note: This document contains an audit solely of the Solidity contracts listed above. Specifically, the audit pertains only to the contracts themselves, and does not pertain to any other programs or scripts, including deployment scripts.

Issue Descriptions and Recommendations

Click on an issue to jump to it, or scroll down to see them all.

M-1 Eigenlayer withdrawals can receive unintended rewards

Security Level Reference

We quantify issues in three parts:

1. The high/medium/low/spec-breaking **impact** of the issue:

- How bad things can get (for a vulnerability)
- The significance of an improvement (for a code quality issue)
- The amount of gas saved (for a gas optimization)

2. The high/medium/low **likelihood** of the issue:

- How likely is the issue to occur (for a vulnerability)

3. The overall critical/high/medium/low **severity** of the issue.

This third part – the severity level – is a summary of how much consideration the client should give to fixing the issue. We assign severity according to the table of guidelines below:

Severity	Description
(C-x) Critical	We recommend the client must fix the issue, no matter what, because not fixing would mean significant funds/assets WILL be lost.
(H-x) High	We recommend the client must address the issue, no matter what, because not fixing would be very bad, or some funds/assets will be lost, or the code's behavior is against the provided spec.
(M-x) Medium	We recommend the client to seriously consider fixing the issue, as the implications of not fixing the issue are severe enough to impact the project significantly, albeit not in an existential manner.
(L-x) Low	The risk is small, unlikely, or may not be relevant to the project in a meaningful way. Whether or not the project wants to develop a fix is up to the goals and needs of the project.
(Q-x) Code Quality	The issue identified does not pose any obvious risk, but fixing could improve overall code quality, on-chain composability, developer ergonomics, or even certain aspects of protocol design.
(I-x) Informational	Warnings and things to keep in mind when operating the protocol. No immediate action required.
(G-x) Gas Optimizations	The presented optimization suggestion would save an amount of gas significant enough, in our opinion, to be worth the development cost of implementing it.

Issue Details

M-1

Eigenlayer withdrawals can receive unintended rewards

TOPIC	STATUS	IMPACT	LIKELIHOOD
Use Cases	Fixed ↗	Medium	Low

In `EigenLayerLSTstakingDecoderAndSanitizer.sol`'s `completeQueuedWithdrawals()`, withdrawal data as well as the tokens the withdrawal is to be received in are decoded so they can be verified to be on the manager's set merkle root, to ensure this interaction is approved:

```
function completeQueuedWithdrawals(
    DecoderCustomTypes.Withdrawal[] calldata withdrawals,
    address[][] calldata tokens,
    uint256[] calldata, /*middlewareTimesIndexes*/
    bool[] calldata /*receiveAsTokens*/
) external pure virtual returns (bytes memory addressesFound) {
    for (uint256 i = 0; i < withdrawals.length; i++) {
        addressesFound = abi.encodePacked(
            addressesFound, withdrawals[i].staker, withdrawals[i].delegatedTo,
        );
        for (uint256 j = 0; j < withdrawals[i].strategies.length; j++) {
            addressesFound = abi.encodePacked(addressesFound, withdrawals[i].st
        )
        for (uint256 j = 0; j < tokens.length; j++) {
            addressesFound = abi.encodePacked(addressesFound, tokens[i][j]);
        }
    }
}
```

Reference: [EigenLayerLSTstakingDecoderAndSanitizer.sol#L32-L49](#)

However, the value `receiveAsTokens` is commented out and not sanitized. This means a strategist can set it as either true or false when making this call. The intended functionality is to set it as true, which results in receiving the tokens defined in tokens, which are verified to be on the tree. In the case where false is set for `receiveAsTokens`, tokens are not received as expected, but shares are received in either the StrategyManager or EigenPodManager depending on the strategy. This may cause issues as a vault likely does not have the ability to properly manage these shares, and are assets the vault was likely not intended to hold.

Remediations to Consider

Revert if the `receiveAsTokens` value for a withdrawal is false, to ensure the intended and verified tokens are received. Alternatively, if receiving shares is desired, consider only reverting if `receiveAsTokens` is false, and the length of the tokens array is non-zero, allowing for a non-token call receiving shares if is verified on the tree.

Disclaimer

Macro makes no warranties, either express, implied, statutory, or otherwise, with respect to the services or deliverables provided in this report, and Macro specifically disclaims all implied warranties of merchantability, fitness for a particular purpose, noninfringement and those arising from a course of dealing, usage or trade with respect thereto, and all such warranties are hereby excluded to the fullest extent permitted by law.

Macro will not be liable for any lost profits, business, contracts, revenue, goodwill, production, anticipated savings, loss of data, or costs of procurement of substitute goods or services or for any claim or demand by any other party. In no event will Macro be liable for consequential, incidental, special, indirect, or exemplary damages arising out of this agreement or any work statement, however caused and (to the fullest extent permitted by law) under any theory of liability (including negligence), even if Macro has been advised of the possibility of such damages.

The scope of this report and review is limited to a review of only the code presented by the Seven Seas team and only the source code Macro notes as being within the scope of Macro's review within this report. This report does not include an audit of the deployment scripts used to deploy the Solidity contracts in the repository corresponding to this audit. Specifically, for the avoidance of doubt, this report does not constitute investment advice, is not intended to be relied upon as investment advice, is not an endorsement of this project or team, and it is not a guarantee as to the absolute security of the project. In this report you may through hypertext or other computer links, gain access to websites operated by persons other than Macro. Such hyperlinks are provided for your reference and convenience only, and are the exclusive responsibility of such websites' owners. You agree that Macro is not responsible for the content or operation of such websites, and that Macro shall have no liability to your or any other person or entity for the use of third party websites. Macro assumes no responsibility for the use of third party software and shall have no liability whatsoever to any person or entity for the accuracy or completeness of any outcome generated by such software.